

OWASP Top 10: Investigacion y analisis de vulnerabilidades

El OWASP Top 10 es una lista de las vulnerabilidades más críticas en aplicaciones web. Estas vulnerabilidades representan los riesgos más comunes que pueden afectar la seguridad de los sistemas y la información de los usuarios en esta investigación vamos a conocer los principales tipos de ataque, el impacto y las formas de usarlos para desarrollar aplicaciones más seguras.

A01. Control de acceso defectuoso	El control de acceso garantiza que los usuarios no puedan actuar fuera de sus permisos. Los fallos suelen provocar la divulgación no autorizada de información, la modificación o destrucción de todos los datos, o la realización de funciones empresariales fuera de los límites del usuario.
A02. Configuración de seguridad incorrecta	Una mala configuración de seguridad se produce cuando un sistema, una aplicación o un servicio en la nube se configura incorrectamente desde el punto de vista de la seguridad, lo que crea vulnerabilidades.
A03. Fallos en la cadena de suministro de software	Los fallos en la cadena de suministro de software son interrupciones u otras deficiencias en el proceso de creación, distribución o actualización de software. Suelen ser causados por vulnerabilidades o modificaciones maliciosas en el código, las herramientas u otras dependencias de terceros de las que depende el sistema.
A04. Fallos criptográficos	En términos generales, todos los datos en tránsito deben cifrarse en la capa de transporte capa 4 del modelo OSI. Los obstáculos anteriores, como el rendimiento de la CPU y la gestión de claves privadas y certificados, ahora se solucionan gracias a que las CPU cuentan con instrucciones diseñadas para acelerar el cifrado, compatibilidad con AES , y la gestión de claves privadas y certificados se simplifica mediante servicios como Let's Encrypt.org.
A05. Inyección	Una vulnerabilidad de inyección es un fallo en una aplicación que permite enviar datos de entrada de usuario no confiables a un intérprete, un navegador, una base de datos o la línea de comandos y provoca que el intérprete ejecute partes de esa entrada como comandos.
A06. Diseño inseguro	El diseño inseguro no es la causa de todas las demás categorías de riesgo principales. Cabe destacar que existe una diferencia entre diseño inseguro e implementación insegura. Distinguimos entre fallos de diseño y defectos de implementación por una razón: tienen causas raíz diferentes, se producen en momentos distintos del

	proceso de desarrollo y requieren soluciones diferentes.
A07. Fallos de autenticación	Cuando un atacante logra engañar a un sistema para que reconozca a un usuario inválido o incorrecto como legítimo, existe esta vulnerabilidad.
A08. Fallos en la integridad del software o de los datos	Los fallos de integridad del software y los datos se relacionan con código e infraestructura que no protegen contra el uso de código o datos no válidos o no confiables, que a menudo se tratan como si fueran confiables y válidos, de esto es cuando una aplicación depende de complementos, bibliotecas o módulos de fuentes, repositorios y redes de distribución de contenido CDN no confiables.
A09. Fallos en el registro y las alertas de seguridad	Sin registro y monitoreo, los ataques y las brechas no se pueden detectar, y sin alertas es muy difícil responder de manera rápida y efectiva durante un incidente de seguridad. El registro, el monitoreo continuo, la detección y las alertas insuficientes para iniciar respuestas activas ocurren en cualquier momento.
A10. Mala gestión de situaciones excepcionales	El manejo inadecuado de condiciones excepcionales en el software ocurre cuando los programas no logran prevenir, detectar y responder a situaciones inusuales e impredecibles, lo que provoca fallos, comportamientos inesperados y, en ocasiones, vulnerabilidades.

- **Casos reales**

Sony Pictures

Año en que pasó en el año 2011

Que Vulnerabilidad paso: SQL Injection acceso a base de datos forzado.

Impacto: a sony pictures le robaron su información delicada obvio de información de sus usuarios algo que es super malo que tengan acceso jente exterior que puede ser usada para afectar de manera mala.

Descripción: Los atacantes explotan una vulnerabilidad SQL Injection para acceder a bases de datos con información sensible.

TalkTalk

Año en que les paso a talk talk: 2015

Que paso: SQL Injection

Impacto: algo super delicado que es el terror de una empresa de clientes fuerte le robaron los datos bancarios

Descripción: Un atacante obtuvo acceso a información personal de miles de clientes mediante consultas SQL maliciosas.

- **Códigos vulnerables y códigos seguros:**

SQL Injection

Vulnerable:

```
const query = "SELECT * FROM users WHERE user = '" + username + "'";
```

Código seguro:

```
const query = "SELECT * FROM users WHERE user = ?";
```

Contraseñas inseguras

Vulnerable:

```
if(password == "123456")
```

Código seguro:

```
const bcrypt = require('bcrypt');
```

SSRF

Vulnerable:

```
fetch(userURL)
```

Código seguro:

```
if (validURL(userURL)) {  
  fetch(userURL)  
}
```

- **Ranking Mas vulnerables:**

1.- Injection:

Puede comprometer mucho a la bases de datos completas se las pueden robar información delicada super rápido lo cual es lo más delicado que puede tener una empresa

2.- Broken Access Control:

Permite acceso indebido a información de manera sencilla.

3.- Authentication Failures:

Facilita robo de cuentas lo cual es un problema en el ámbito empresarial hacía los clientes que es cierto los puedes proteger pero si llegan a ser más rápidos los que te están haciendo el ataque tienes serios problemas.

4.- Security Misconfiguration:

Errores muy comunes y muy peligrosos

5.- Vulnerable Components:

Dependencias viejas son super explotadas

- **Conclusión sobre la vulnerabilidad más críticas**

Esta práctica me ayuda a saber la importancia que es la seguridad en el desarrollo de aplicaciones y los riesgos que puede existir actualmente en páginas web, y El OWASP Top 10 pude identificar las vulnerabilidades más comunes y peligrosas que pueden afectar a las empresas como a usuarios.

investigando observé que muchas vulnerabilidades ocurren por errores simples como malas configuraciones o hasta validaciones incorrectas o uso de componentes que ya no son muy comunes o desactualizados, También vi que los ataques pueden provocar robo de información delicada y lo mas importante pérdida económica y pues la reputación de la empresas.

así que como futuro desarrollador aplicare medidas de seguridad desde las primeras etapas del desarrollo y no dejar la seguridad solamente al final del proyecto.